Threat Analysis: The TeamPCP Supply Chain Compromise



Memori CTI

The Initial Breach – Compromising a Trusted Scanner

The recent supply chain attacks by TeamPCP began with Trivy, a popular open-source vulnerability scanner maintained by Aqua Security. Rather than tricking users into downloading fake files, the attackers used compromised credentials to hijack 75 out of 76 historical version tags for the official Trivy GitHub Action. When automated developer systems requested these familiar versions, they unknowingly downloaded a hidden Python script.

This "infostealer" malware was built to hunt through systems and extract sensitive data like cloud provider credentials, database passwords, and cryptocurrency wallets. If the network transfer to the attackers failed, the malware used the victim's own access token to create a public backup repository named "tpcp-docs" on the victim's GitHub account.

Escalation – From Data Theft to Destructive Wipers

Following the initial breach, the threat actors expanded their reach to Docker Hub, pushing infected image tags to distribute a self-spreading computer worm known as CanisterWorm. They also engaged in public defacement, using a compromised service account to rename 44 of Aqua Security's internal code repositories in just two minutes. They exposed proprietary source code and changed descriptions to "TeamPCP Owns Aqua Security". More alarmingly, the group deployed a custom wiper malware aimed at Kubernetes clusters.

The malware checked the location of infected systems; if a system was in Iran, a specialized "kamikaze" container completely wiped the data and forced a reboot. For systems outside Iran, it quietly installed CanisterWorm as a backdoor.

Moving Laterally – The Checkmarx Breach

In a textbook example of a cascading supply chain attack, the group used the credentials stolen during the Trivy breach to compromise Checkmarx. Just four days after the initial incident, researchers discovered two official Checkmarx GitHub Actions workflows were infected with the exact same data-stealing malware. To hide from security teams, the attackers upgraded their deception tactics by registering a fake domain named "checkmarx[.]zone". This typosquatting technique made the malicious data theft look like routine communication with Checkmarx's actual servers. For this phase, they tweaked their backup strategy, creating repositories named "docs-tpcp" instead of the previously used "tpcp-docs"

Targeting the Workspace and Securing the Pipeline

The Checkmarx compromise eventually reached developers' personal workspaces through malicious Visual Studio Code extensions. When installed, the malware scanned for cloud service credentials and reached out to the fake Checkmarx domain (hosted at the malicious IP address 83.142.209[.]11:443) to download a secondary payload. Any harvested credentials were then encrypted and exfiltrated directly to checkmarx[.]zone/vsx packaged as a file named tpcp.tar.gz. This tool established a permanent foothold, checking the attacker's server every 50 minutes. It even included a bizarre kill switch: it would abort if the server responded with the word "youtube," which redirected to a Queen song. Checkmarx clarified there was no impact on customer data. To defend against these evolving threats, security experts advise teams to rotate all secrets immediately and stop relying on simple version tags. Instead, automated systems must be pinned to immutable cryptographic hashes (commit SHAs) to ensure code integrity.